

PROJECT CAREER DOSSIER

AppTrana WAAP / WAF Implementation

Detailed Experience, Technical Work, Testing, Governance and Resume Evidence

Prepared for Nikhil Wadhwani | KSB Limited | August 2026

How to use this document

This is a comprehensive evidence inventory for feeding into another LLM, preparing a resume, building interview stories, writing performance-review content, and documenting project continuity. It intentionally includes operational detail beyond what should appear on a public resume. Use the Resume-Safe Translation section to avoid disclosing KSB hostnames, IP addresses, vendor contacts, credentials, or internal architecture.

Project	AppTrana WAAP/WAF onboarding and operationalization for KSB web and API applications
Primary contribution	Application inventory validation, self-onboarding, SSL configuration, vulnerability scanning, API onboarding, DNS cutover coordination, protection validation, reporting analysis, vendor management, testing, SOP creation and security hardening
Platform	Indusface AppTrana WAAP/WAF, Tata CDN, AppTrana WAS/API scanning
Application estate	33 applications included in the AppTrana daily-summary population, with additional internal candidates not yet onboarded
Working model	KSB internal coordination plus Indusface fully managed service and escalation support
Document status	Evidence-based summary compiled from project trackers, emails, PDFs, screenshots, testing outputs and working discussions

1. Executive Summary of Contribution

Nikhil supported the end-to-end implementation and operational validation of AppTrana for KSB's internet-facing web and API estate. The work went beyond portal administration. It included discovery and data reconciliation, technical onboarding, vulnerability-scan troubleshooting, API specification handling, SSL certificate configuration, DNS redirection readiness, WAF protection-mode tracking, origin-bypass testing, managed-service governance, CDN assessment, and creation of repeatable internal procedures.

- Coordinated onboarding and status validation across a 33-application AppTrana estate containing web applications, APIs, production systems, UAT systems, shared origins and multiple business owners.
- Converted incomplete and inconsistent application inventories into implementation-ready information covering FQDN, public/NAT IP, application type, ownership, certificate status, scan status, protection mode, DNS redirection and AppTrana CNAME.
- Identified and pursued root causes for vulnerability scans that failed because HTTP scan URLs were configured for applications that were available only over HTTPS.
- Differentiated web application onboarding from API onboarding and established the need for API base paths, Postman/OpenAPI inputs, endpoint selection, authentication handling and separate API licensing.
- Validated external routing through AppTrana and independently demonstrated that a known public origin could still be reached directly, creating an origin-bypass path; obtained the official WAF NAT allowlist and recommended origin-protection design from Indusface.
- Created professional internal SOPs for AppTrana application onboarding and SSL certificate configuration using portal screenshots and operational controls.
- Analyzed AppTrana daily reports, challenged unexplained protection classifications, reconciled portal metrics with internal status, and used contractual QoS and escalation documents to drive vendor accountability.
- Evaluated Tata CDN functionality, cache behavior, bandwidth reporting, purge controls, TTL, Always Cache/Never Cache rules, HTTPS support and phased adoption risks for web and API applications.

2. Project Scope and Stakeholder Environment

2.1 Technical scope

- AppTrana application onboarding for web and API applications.
- Automated web vulnerability scanning and Postman-based API scanning.
- WAF protection modes including Log Only and Log and Block.
- SSL certificate upload and maintenance using PFX or certificate components.
- DNS redirection from existing A records to AppTrana-provided CNAME targets.
- External-versus-internal split-DNS behavior for applications such as the KSB intranet.
- Origin protection through firewall allowlisting of AppTrana WAF NAT and scanner NAT ranges.
- Bot, DDoS, rate-threshold, attack-log and access-log interpretation.
- Tata CDN caching and bandwidth-management assessment.
- Managed-service SLAs, escalation paths, reporting and false-positive/custom-rule workflows.

2.2 Stakeholders coordinated

- KSB cyber security and DTC management.
- Application owners, business users, developers and third-party vendors.
- KSB DNS, network and firewall teams.
- KSB certificate owners and infrastructure teams.
- Indusface account/onboarding contacts and Managed Security Services engineers.
- Indusface technical support, service leadership, product leadership and sales escalation chain.

3. Detailed Workstreams and Tasks Performed

3.1 Application discovery and inventory reconciliation

- Collected and reviewed multiple workbooks containing server IPs, FQDNs, SAN values, public IPs, Web/API type, owners, developers and DNS records.
- Compared the Complete Application List, Application Review, AppTrana WAF Status and AppTrana sanity-check workbook to identify stale or conflicting information.
- Identified significant IP mismatches across the CBE/CDSS application group and flagged old values in the application review inventory.
- Identified incomplete rows, missing onboarding status, missing CNAMEs, blank protection mode and inconsistent dates.
- Distinguished applications listed internally from the 33 applications actually counted in AppTrana reporting.
- Validated known APIs and asked Indusface to cross-check any APIs incorrectly onboarded as web applications.

3.2 Web application onboarding

- Logged in to the AppTrana dashboard and used Add Application.
- Entered the FQDN, selected the Web Application option and validated auto-populated origin and scan URLs.
- Opened plan selection, chose the enterprise promo-code/license path, assigned an available license and completed onboarding.
- Handled optional SSL configuration during onboarding or deferred SSL update until after onboarding.
- Confirmed successful onboarding and updated the internal implementation tracker.

3.3 API onboarding and API security workflows

- Investigated the difference between Web Application, API Application and combined Web plus API onboarding.
- Clarified that the API host is the API FQDN and that the API base path is the common path prefix, not necessarily the Swagger UI path.
- Tested common API paths and confirmed Swagger UI availability for the CDSS API while root and generic /api paths returned 404.
- Coordinated separate API licenses and conversion/onboarding of cbemtcmodel and ksbcddssapi as API Applications.
- Identified dmsdatamart as an API requiring correction from Web to API classification.
- Uploaded Postman collections for API scanning and sought guidance on safe endpoint selection to avoid triggering destructive POST, reset, import or update operations.
- Established that API scanning needs a valid Postman/OpenAPI definition and may require authentication/token handling rather than relying on ordinary web crawling.

3.4 Postman collection validation and repair

- Investigated an AppTrana upload failure for a supplied Postman JSON collection.
- Parsed the file and identified invalid JSON nesting, an unclosed User folder before the Dashboard folder, trailing commas and extra closing braces near the StatusProcess section.
- Produced a structurally valid Postman Collection v2.1-compatible JSON while preserving API endpoints, methods, request bodies, authorization structure and variables.
- Validated a repaired collection containing nine folders and 79 requests.
- Flagged that sample credentials and bearer-token flows must be confirmed as non-production or removed/rotated before external use.
- Communicated back to the application team that the submitted file was not valid and requested a corrected official export.

3.5 SSL certificate configuration

- Navigated through Applications and Groups, domain selection and Application Configuration.
- Opened SSL Details, uploaded a complete PFX certificate, entered the protected password, updated the certificate and saved the configuration.
- Validated HTTPS behavior, certificate common name/SAN, issuer, expiry and certificate-chain expectations.

- Documented safe handling of PFX files, private keys and passwords, including change control and rollback considerations.
- Created a professional screenshot-based KSB internal SSL Configuration SOP.

3.6 Vulnerability scanning and remediation workflow

- Investigated why some applications scanned successfully while others failed or terminated.
- Challenged the initial ambiguity around cached PoC DNS and obtained confirmation that successful scans were not caused by retained DNS/cache from the trial.
- Drove application-wise failure analysis rather than accepting repeated generic scan retries.
- Confirmed the actual root cause: scan URLs had been configured with HTTP for applications accessible only through HTTPS; Indusface corrected the URLs.
- Coordinated allowlisting of Indusface scanner addresses.
- Interpreted vulnerability statuses: Virtually Patched, Fix in Code, Need CR/Request Custom Rule, Whitelist, Request POC and no-action low-severity findings.
- Established that virtual patching is compensating protection, not removal of the underlying defect.
- Established that Fix in Code findings must be assigned to application owners/developers and rescanned after remediation.
- Established that Need CR findings should be submitted to Indusface for custom WAF-rule analysis and implementation.
- Avoided indiscriminate whitelisting and required false-positive evidence or formal risk acceptance.

3.7 DNS redirection and sanity-check coordination

- Requested application-wise CNAME targets, record-change requirements, prerequisites, validation and rollback guidance.
- Reviewed AppTrana's sanity-check workbook containing host, origin IP, host-file entry, without-WAF response, with-WAF response, health-check URL and CNAME.
- Compared without-WAF and with-WAF responses to identify safe candidates and applications returning 403, 404, 500 or 503 before cutover.
- Identified incorrect or suspicious health-check mappings, such as a checklist application pointing to a configurator URL.
- Recommended phased cutover rather than a bulk all-application change.
- Understood the operational model: replace individual public A records with AppTrana CNAME targets, while retaining documented old A-record values for rollback.
- Validated that one shared FQDN can contain multiple application paths and that FQDN-level WAF routing and path-level scan/health configuration must be tracked separately.

3.8 Origin-protection and WAF-bypass validation

- Confirmed split DNS for ksbnet: internal users resolved directly to the internal server while external users resolved through the AppTrana CNAME/IndusGuard infrastructure.
- Used curl --resolve to override DNS for a single request while retaining TLS SNI and HTTP Host headers for the application hostname.
- Validated the normal external path connected to an AppTrana IPv6 address and returned HTTP 200.
- Validated the forced-origin path connected directly to the KSB public origin address and returned HTTP 200 from Microsoft IIS/ASP.NET.
- Used verbose curl output and the remote_ip write-out variable to prove the destination IP was accepted and not ignored or sourced from Windows DNS cache.
- Flushed and inspected the Windows DNS resolver cache to eliminate cached-DNS ambiguity.
- Exported and analyzed AppTrana access logs, distinguishing normal curl requests from attempted direct-origin tests by source IP and User-Agent.
- Recommended unique User-Agent markers for conclusive WAF-versus-origin log correlation.
- Obtained Indusface confirmation that origin protection should allow only AppTrana WAF NAT and scanner NAT ranges and block other internet sources.
- Captured the operational risk that shared public IPs or non-WAF applications could be broken by a broad deny rule.
- Defined the safe implementation sequence: dependency discovery, allow rules first, validation, deny-all-other-public-sources, controlled change window and rollback.

3.9 Protection-status and reporting analysis

- Analyzed the AppTrana daily summary showing zero Fully Protected, 15 Partially Protected and 18 Unprotected applications, with a 22 percent protection score.
- Reconciled the 33-site denominator against the onboarded estate and stopped counting internal applications that were not yet onboarded.
- Compared portal reporting with the internal tracker, which showed 15 applications in Log and Block and the remainder largely in Log Only.
- Challenged why Log and Block applications remained classified as Partially Protected and asked for the exact fully protected criteria.
- Identified likely additional controls such as origin protection, active routing, health, SSL, bypass state or other platform criteria.
- Analyzed vulnerability totals, code-fix versus custom-rule counts, attack blocks, bot events, no recent scan counts and ambiguous CDN metrics.
- Noted that attack-block totals required application/rule-level validation and that zero DDoS events did not itself prove DDoS readiness.
- Tracked the failure to receive daily summary emails despite weekly reports being delivered and notifications enabled.

3.10 DDoS, bot and rate-limiting analysis

- Clarified that a threshold such as 300 requests per minute per source IP is source-based application-layer rate limiting.
- Identified the blind spot where many distributed clients can each remain below the per-IP threshold while generating a large aggregate request volume.
- Asked whether AppTrana provides aggregate thresholds, distributed DDoS detection, bot behavior scoring, path-level controls, ASN/country controls and challenge mechanisms.
- Connected the analysis to AppTrana Managed Services QoS commitments for DDoS and bot response/notification.

3.11 Tata CDN assessment and rollout planning

- Confirmed through Indusface that Tata CDN is included in KSB's purchased AppTrana scope.
- Reviewed official AppTrana Manage Bandwidth and CDN FAQ documentation.
- Understood that enabling the CDN toggle automatically caches eligible static extensions across the selected FQDN; individual links are needed only for Always Cache/Never Cache exceptions.
- Confirmed supported default static types, default 24-hour cache duration, HTTPS certificate reuse, cache toggle, TTL configuration, Purge All, Custom Purge, Always Cache, Never Cache and Pending Action workflows.
- Identified benefits: faster external delivery, reduced origin load, reduced bandwidth and improved resilience during traffic spikes.
- Identified risks: stale content, unsafe caching of authenticated or user-specific content, API response leakage, cache-key mistakes, operational complexity and release-related purge requirements.
- Recommended no account-wide enablement; instead classify the estate, pilot a low-risk static-heavy web application, use conservative caching, add Never Cache rules, validate functionality/performance/security and expand only when value is measurable.
- Established that CDN is a performance layer, not a substitute for WAF or origin protection, and that Not Behind Tata CDN should not automatically mean Not Protected by WAF.

3.12 Vendor governance, support and escalation

- Used written scope and QoS documents to confirm that Indusface accepted a fully managed WAF operating model, application onboarding, monitoring, tuning, virtual patching, reporting, guidance and false-positive management.
- Captured support SLAs: P1 response within two hours with four-hour updates, P2 within four hours, P3 within 12 hours and P4 within 24 hours.
- Captured managed-service commitments for five-minute DDoS/bot response and virtual patch timelines for Critical, High and Medium findings.
- Used technical, service, product and sales escalation paths when replies or remediation stalled.
- Drafted concise, evidence-based emails requesting exact failure reasons, completion timelines, portal-side validation and proactive issue resolution.
- Balanced firmness with working relationships by distinguishing KSB ownership from AppTrana portal/configuration ownership.

4. Technical Testing and Commands Used

The following commands represent the key validation methods used during the project. Replace internal hostnames and addresses before using them outside KSB.

Purpose	Command
Internal and external DNS resolution	nslookup <application-fqdn> nslookup <apptrana-cname>
Normal path: show actual connected WAF address	curl -skI -o NUL -w "NORMAL PATH - Connected to: %{remote_ip} HTTP: %{http_code}\n" https://<application-fqdn>/
Forced-origin path: bypass public DNS for one request	curl -skI --resolve <application-fqdn>:443:<origin-ip> -o NUL -w "FORCED ORIGIN - Connected to: %{remote_ip} HTTP: %{http_code}\n" https://<application-fqdn>/
Verbose proof of connection destination	curl -vki --resolve <application-fqdn>:443:<origin-ip> https://<application-fqdn>/
Unique User-Agent for log correlation	curl -skI -A "DIRECT-ORIGIN-TEST" --resolve <application-fqdn>:443:<origin-ip> -o NUL -w "Connected IP: %{remote_ip} HTTP: %{http_code}\n" https://<application-fqdn>/
Windows DNS cache inspection	ipconfig /displaydns ipconfig /flushdns
API path and Swagger testing	curl -I https://<api-fqdn>/api curl -I https://<api-fqdn>/api/v1 curl -I https://<api-fqdn>/swagger/index.html

5. Procedures and Documentation Created

- AppTrana Application Onboarding SOP: professional Word document with cover page, scope, prerequisites, required inputs, step-by-step portal screenshots, promo-code/license assignment, optional SSL handling, post-onboarding checks, redirect/multiple-path handling, mistakes to avoid, responsibility summary and completion criteria.
- AppTrana SSL Certificate Configuration SOP: professional Word document with secure certificate handling, prerequisites, domain selection, Application Configuration navigation, SSL Details editing, PFX upload, password handling, validation, troubleshooting, change control and completion criteria.
- Operational mail templates: DNS redirection request, API classification validation, scan-failure analysis, configuration timeline request, origin-protection query, CDN-scope clarification, Postman-file correction request and API scan-safety confirmation.
- Internal status tracking: application FQDN, Web/API type, public/NAT IP, license/onboarding, scan result, protection mode, DNS redirection, CNAME, certificate status, old-WAF removal, responsible person, business owner and developer/vendor.

6. Key Problems Identified and Resolution Path

Problem	Resolution / Outcome
Scans failed or terminated	HTTP scan URL was configured while the application required HTTPS. Indusface corrected scan URLs; scanner IP allowlisting and rescans followed.
API onboarded as web application	Identified incorrect classification, requested separate API licensing and re-onboarding/configuration as API Application.
API scan would not start	Recognized requirement for Postman/OpenAPI input, endpoint selection and authentication details.
Postman upload error	Demonstrated malformed JSON structure, repaired the collection and requested an official corrected export from the owner.

Zero Fully Protected despite Log and Block	Reconciled the 33-app scope, challenged AppTrana's classification and identified origin protection as a likely missing control.
Origin directly reachable	Demonstrated normal WAF path versus forced-origin path with curl, confirmed external direct reachability and obtained official NAT allowlist/remediation guidance.
Bulk origin restriction could break services	Raised shared-public-IP and non-WAF dependency risk; required service inventory and controlled firewall implementation.
Tata CDN shown as missing for all applications	Confirmed CDN was included in scope, separated performance from security, and designed a selective pilot instead of enabling it globally.
Daily report not delivered to one user	Raised portal notification issue while confirming weekly reports worked.
Inconsistent application inventories	Cross-compared workbooks, identified IP/date/status mismatches and required authoritative owner/DNS validation before cutover.
Ambiguous per-IP DDoS threshold	Distinguished single-source rate limiting from distributed DDoS and requested aggregate/bot behavior controls.
Unclear vulnerability actions	Mapped Virtually Patched, Fix in Code, Need CR, POC, Whitelist and Jira tracking to owners and safe processes.

7. Quantifiable Evidence and Scale

Use only claims you can defend

The metrics below are drawn from project records and should be framed carefully. Do not imply sole ownership of vendor-managed activities. Use verbs such as coordinated, validated, analyzed, identified, documented and drove resolution unless direct ownership is documented.

Evidence area	Defensible statement
Application scope	33 applications in the AppTrana daily-summary population, with web and API workloads.
Protection state analyzed	15 applications shown as Partially Protected in daily reporting and tracked internally in Log and Block; 18 shown Unprotected/remaining largely Log Only at the reporting snapshot.
Vulnerability summary analyzed	205 Medium, 19 High and 19 Critical findings in the daily summary; 12 code-fix items and 141 custom-rule items were reported.
Attack summary analyzed	Daily summaries included hundreds to more than 1,000 blocked attacks and bot events; application/rule breakdown was requested for validation.
API collection repaired	Nine folders and 79 requests preserved in a corrected valid JSON collection.
SOPs created	Two professional screenshot-based SOPs: application onboarding and SSL certificate configuration.
Origin validation	Normal WAF path and forced-origin path compared using actual remote IP output and HTTP status, with access-log correlation.

Scanner allowlisting

Five scanner addresses were provided and tracked for scan reachability.

Managed service governance

SLA, QoS and multi-level escalation documents analyzed and operationalized.

8. Skills Demonstrated

WAAP/WAF

Reverse-proxy WAF architecture • Log Only versus Block mode • Origin protection • Virtual patching • Custom rules • False-positive handling • Bot/DDoS concepts • Attack/access log interpretation

DNS and network

A records and CNAME cutover • Split DNS • TTL and cached DNS behavior • Public NAT/origin mapping • Firewall allowlisting • Shared-IP dependency analysis • Rollback planning

Web and API security

API host/base path • Swagger/OpenAPI • Postman collections • Bearer-token flows • Endpoint safety • Web/API classification • HTTP status analysis • TLS/SNI/Host-header behavior

Operations

Application onboarding • SSL/PFX configuration • Vulnerability scanning • Change windows • UAT and validation • Runbooks/SOPs • Status trackers • Incident escalation

Analysis and tooling

curl • nslookup • Windows DNS cache tools • CSV/access-log analysis • Excel tracker reconciliation • JSON validation/repair • Evidence-based root-cause analysis

Communication

Vendor coordination • Application-owner engagement • Concise escalation emails • Managed-service accountability • Risk translation for managers • Cross-team action planning

9. Resume-Safe Translation

Confidentiality warning

Do not place internal FQDNs, public/private IP addresses, certificate details, vendor phone numbers, credentials, exact vulnerability counts tied to KSB, or internal names on a public resume. Generalize the scale and technology while preserving the achievement.

9.1 Resume bullet bank

- Coordinated onboarding and operational validation of 30+ web and API applications on a managed WAAP/WAF platform, covering DNS cutover, SSL configuration, vulnerability scanning, protection modes and business-owner validation.
- Identified and resolved application-scan failures caused by incorrect HTTP/HTTPS scan configuration, coordinating scanner allowlisting, corrected scan URLs and successful rescans.
- Led API-security onboarding workflows using Postman/OpenAPI specifications, API base-path analysis, authentication handling and safe endpoint selection for automated scanning.
- Validated WAF traffic routing and uncovered direct-origin reachability using DNS override, TLS/SNI-aware curl testing and access-log correlation; drove an origin-protection design based on vendor NAT allowlisting and firewall restriction.
- Created repeatable, screenshot-based SOPs for WAAP/WAF application onboarding and SSL certificate management, improving operational consistency and knowledge transfer.
- Reconciled multiple application, DNS and WAF trackers to identify stale IP mappings, incomplete ownership, inconsistent protection states and cutover risks before production changes.

- Analyzed vulnerability findings and established remediation ownership across virtual patching, custom WAF rules, application code fixes, false-positive validation and risk acceptance.
- Assessed managed CDN capabilities and designed a phased rollout strategy balancing performance improvements with cache safety for authenticated, dynamic and API workloads.
- Used managed-service SLAs, QoS commitments and escalation matrices to drive vendor responsiveness, root-cause transparency and application-level remediation plans.
- Built executive-ready status views linking application inventory, scan health, certificate status, DNS routing, WAF mode, origin protection and outstanding owner actions.

9.2 Possible resume project entry

AppTrana WAAP/WAF Implementation and Operationalization | KSB Limited

- Coordinated onboarding and validation of 30+ web/API applications across DNS, SSL, vulnerability scanning, protection mode and managed-service workflows.
- Diagnosed scan failures, corrected API/web classification and Postman collection issues, and established safe automated API-scanning procedures.
- Identified a direct-origin exposure through controlled network testing and drove vendor-confirmed origin-lockdown planning using WAF NAT allowlisting.
- Created internal onboarding and certificate-management SOPs and reconciled technical trackers to improve implementation governance and auditability.

10. Interview Story Bank Using STAR

Origin-bypass discovery

Situation: Applications were routed through a managed WAF, but the portal still showed Partially Protected. Task: Determine whether routing and origin protection were complete. Action: Compared internal split DNS and external DNS, used curl remote-IP output and --resolve to test the normal WAF path versus the public origin, flushed DNS to remove ambiguity, analyzed access logs, and obtained the vendor's NAT allowlist and remediation guidance. Result: Demonstrated that the origin remained externally reachable and defined a controlled firewall-hardening plan that preserved internal access and avoided breaking shared services.

Failed vulnerability scans

Situation: Some applications scanned successfully while others repeatedly failed. Task: Obtain a direct root cause instead of repeated retries. Action: Escalated for application-wise analysis, ruled out retained trial DNS as the explanation, and correlated application behavior with scan configuration. Result: Vendor confirmed HTTP scan URLs had been used for HTTPS-only applications, corrected the URLs and enabled rescanning.

API scan onboarding

Situation: An API could be onboarded as a web application, but API-only onboarding produced errors and API scans required additional input. Task: Establish the correct API workflow. Action: Analyzed API host/base path, validated Swagger availability, coordinated separate API licensing, handled Postman collection upload and endpoint-selection safety, and repaired malformed JSON. Result: API applications were correctly categorized and scan preparation became repeatable and auditable.

CDN adoption decision

Situation: Daily reports showed all applications not behind an included CDN. Task: Decide whether to enable CDN portfolio-wide. Action: Reviewed official product documentation, separated CDN performance from WAF protection, analyzed cache defaults and risks, classified web/API/dynamic workloads, and designed a one-application pilot with Never Cache rules, validation and rollback. Result: Avoided a risky mass enablement and created a measurable phased adoption approach.

Cross-workbook reconciliation

Situation: Multiple inventories contained conflicting IPs, incomplete fields and different application counts. Task: Determine the authoritative implementation state. Action: Compared DNS records, public IPs, ownership, status and AppTrana sanity

data across workbooks and separated onboarded from non-onboarded applications. Result: Identified mismatches and improved confidence in cutover and reporting decisions.

11. Technical and Operational Lessons Learned

- A DNS CNAME cutover is necessary but not sufficient for complete WAF protection; the origin must also reject direct public traffic.
- `curl --resolve` is a precise way to bypass DNS for a single request while preserving the correct HTTPS hostname through SNI and Host headers.
- Windows DNS-cache output does not show curl's temporary `--resolve` mapping; verbose connection output or `%{remote_ip}` is stronger evidence.
- Internal split DNS can coexist safely with external WAF routing when public-origin restrictions are applied only to the external NAT path.
- HTTP status parity with and without WAF helps separate WAF problems from pre-existing application/path errors.
- API scanning is not ordinary website crawling; it depends on valid specifications, authentication and careful handling of state-changing operations.
- Virtual patching is compensating mitigation, not code remediation.
- Per-source rate limiting is not sufficient evidence of distributed DDoS protection.
- CDN is optional performance optimization and should not be confused with WAF protection completeness.
- Blocking a shared public IP without dependency analysis can cause an outage for unrelated applications.
- Managed-service scope and QoS documents are operational tools, not procurement paperwork; they help enforce ownership, timelines and escalation.

12. Approximate Project Chronology

Stage	Work performed
Initial planning and inventory	Collected application lists, ownership, public IPs, SSL details and AppTrana onboarding prerequisites.
Portal onboarding	Self-onboarded applications using FQDN, origin, scan URL and enterprise promo-code/license assignment.
Scan troubleshooting	Investigated failed scan behavior, obtained application-wise analysis and corrected HTTP-to-HTTPS scan URL issues.
API workstream	Clarified API base path, reclassified APIs, coordinated API licensing and prepared Postman/API scan inputs.
SSL operationalization	Uploaded certificates, validated HTTPS and created certificate configuration SOP.
DNS and go-live	Obtained CNAMEs, reviewed sanity-check outputs, coordinated phased redirection and tracked Log Only/Log and Block status.
Reporting and hardening	Analyzed daily summaries, reconciled 33 applications, investigated partial protection and proved direct-origin reachability.
Origin protection	Obtained WAF NAT ranges and vendor confirmation, then defined dependency checks and controlled firewall restriction.
CDN assessment	Confirmed scope inclusion, reviewed official docs and built selective pilot strategy.

13. Open Items and Recommended Next Steps

- Complete public-origin dependency discovery for every shared NAT/public IP before firewall restriction.
- Implement allow rules for confirmed AppTrana WAF NAT, scanner and monitoring sources, then deny other public access during a change window.
- Retest normal WAF path, forced-origin path and internal split-DNS path after restriction.
- Obtain AppTrana's application-wise Fully/Partially/Unprotected criteria and pending-control list.
- Complete API reclassification for dmsdatamart and validate API scan inputs and selected endpoints.
- Complete custom-rule requests and application-owner code remediation for reported findings.
- Pilot Tata CDN on one low-risk static-heavy web application; measure cache hit/data served, performance and functional impact.
- Resolve daily-email delivery for the project user and consolidate recurring operational reporting.
- Maintain the onboarding, SSL, DNS, API, origin-protection and CDN procedures as a controlled internal runbook.

14. Internal Evidence Sources Used

- APPTRANA WAF STATUS trackers and PDF status exports.
- KSB_Project sanity-check workbook with host, origin, response, health-check and CNAME details.
- Complete Application List and Application Review workbooks.
- AppTrana daily-summary Outlook PDF exports.
- Indusface Sales Escalation Matrix, Technical Escalation Matrix and Managed Services QoS documents.
- March 2026 email confirming managed-service requirements and SLA commitments.
- Portal screenshots for application onboarding, SSL configuration, API scanning and vulnerability actions.
- Postman collection supplied for the KSB CDSS API and corrected validation copy.
- curl, nslookup and Windows DNS-cache outputs.
- AppTrana access-log CSV exports.
- Official Indusface documentation for Manage Bandwidth and FAQs on CDN.

15. Suggested Prompt for Resume Curation in Another LLM

Use this document as an evidence inventory for my AppTrana WAAP/WAF project at KSB. Build an ATS-friendly cybersecurity resume project section and interview story bank. Do not expose KSB hostnames, IP addresses, credentials, vendor personal contacts, internal names, or confidential architecture. Preserve the scale as 30+ applications and describe my role accurately using verbs such as coordinated, validated, analyzed, identified, documented, tested, and drove resolution. Do not claim sole ownership of vendor-managed work. Prioritize measurable impact, origin-protection testing, API onboarding, vulnerability scan troubleshooting, DNS/SSL operations, SOP creation, managed-service governance, CDN assessment and cross-team coordination. Produce: (1) a 4-bullet resume entry, (2) a 2-line professional summary, (3) 10 skill keywords, (4) 5 STAR interview stories, and (5) a list of claims that require further evidence before use.

16. Accuracy and Claim Discipline

Resume truth standard

This project demonstrates substantial hands-on security engineering, coordination and analysis. Keep claims exact. Say "identified and validated direct-origin reachability" rather than "eliminated WAF bypass" until the firewall restriction is implemented and retested. Say "coordinated onboarding of 30+ applications" rather than "independently deployed the entire estate" unless that is documented. Distinguish vendor-provided virtual patching from application code remediation and distinguish planned CDN rollout from completed production enablement.